USER MANUAL

INFORMATION SECURITY RISK MANAGEMENT (ISRM) TOOLKIT 5X5 RISK MATRIX

Table of Contents

1.0 Introduction 1
2.0 Installation and Macro setup 1
3.0 Main Page 4
4.0 The Lookup Sheets 7
5.0 Team Profile 10
6.0 Risk Assessment for Asset-based Approach 11
7.0 Risk Treatment Plan for Asset-based Approach 19
8.0 Risk Assessment for Event-Based Approach 25
9.0 Risk Treatment Plan For Event-Based Approach 31

1.0 Introduction

This user manual provides guidance on the Information Security Risk Assessment (ISRM) Toolkit for the 5x5 risk matrix, developed in Microsoft Excel. It is intended to assist users in performing risk assessments and organizing risk treatments, supporting three distinct risk approaches: asset-based, event-based, and a combination of both.

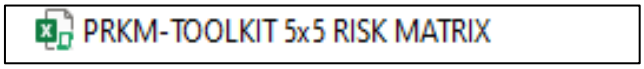
This guide provides detailed instructions, starting with the installation of the ISRM toolkit and the process for enabling macros. The subsequent steps cover main page navigation to confirm the selected risk assessment approach, followed by entering risk data into the risk assessment and risk treatment sections.

2.0 Installation and Macro setup

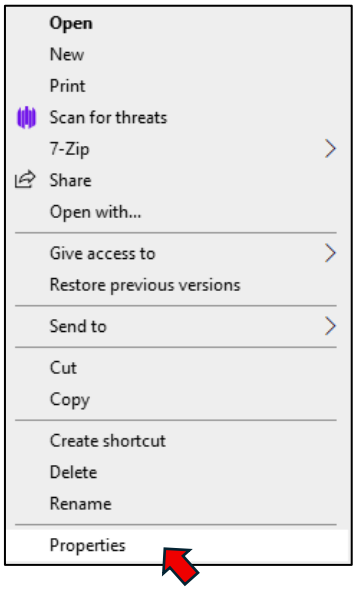
Please follow to the following steps to proceed with the installation of ISRM Toolkit.

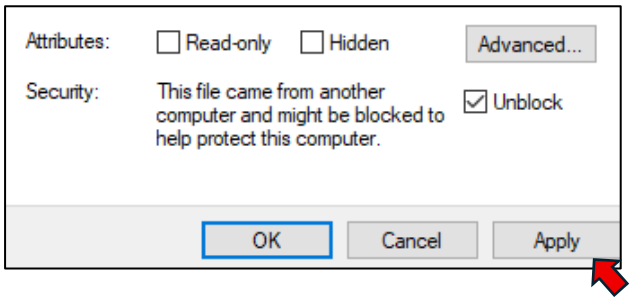
a) Download the ISRM Toolkit

i) Locate the ISRM Toolkit file you have just downloaded.



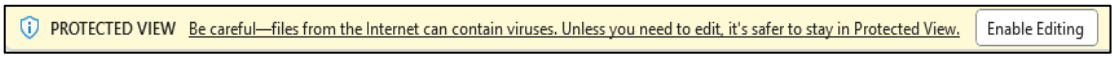
ii) Right-click the file and select Properties. Under the General tab, check the <Unblock box>, then click <Apply>.



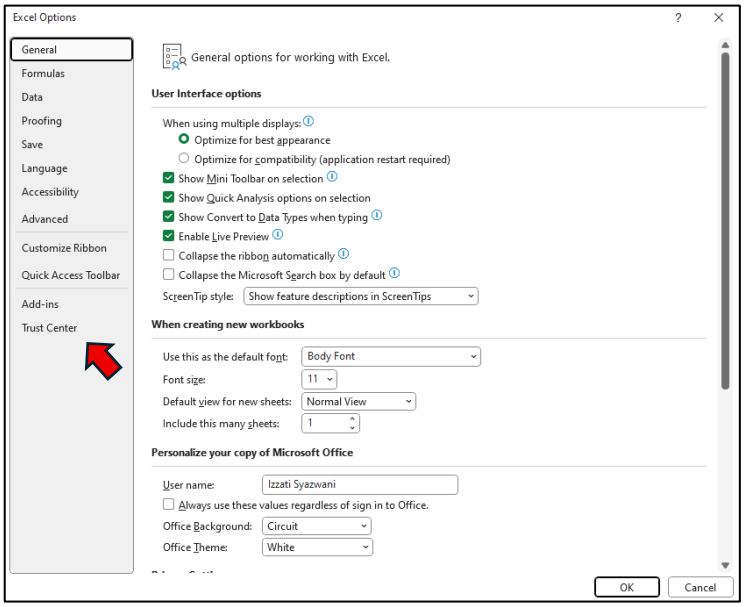


b) Enable Macro in Microsoft Excel

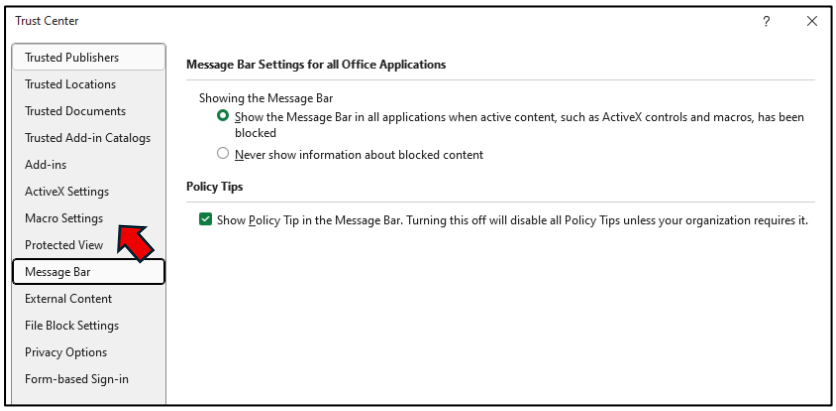
1. Open the ISRM Toolkit. If a yellow notification bar appears at the top stating "Protected View", click <Enable Editing>.



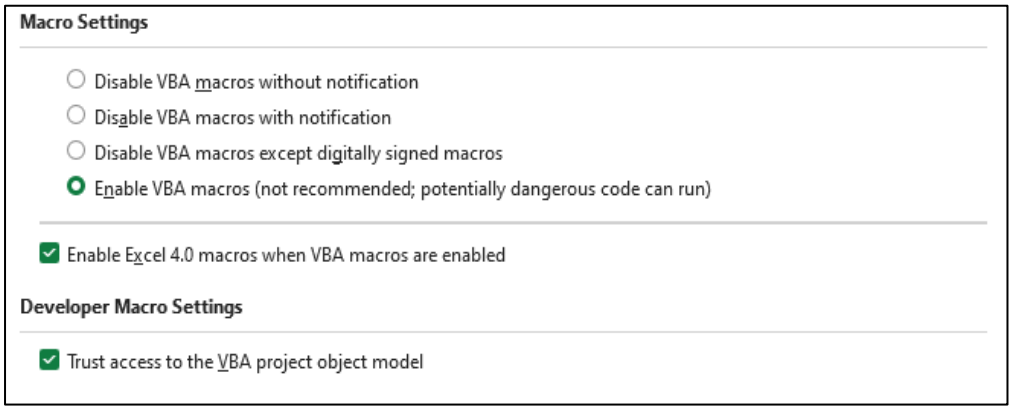
2. Go to the File tab located in the top-left corner. Scroll down and click Options. In the Options window, select Trust Center (bottom-left). Then, on the right-hand side, click <Trust Center Settings>.



3. In the new window, select <Macro Settings>.



4. Tick all the checkboxes as shown below. Click <OK>, then click <OK> again to close the settings. Close and reopen the toolkit file to apply the changes.



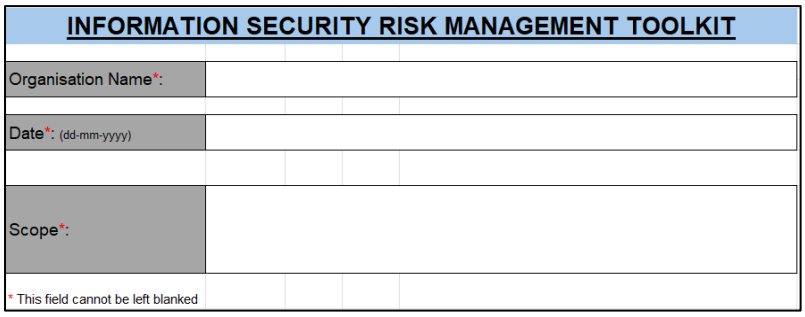
3.0 Main Page

The Main Page sheet is the default view when the ISRM Toolkit is opened. It is important to complete all the required fields on the Main Page before proceeding to the subsequent steps in the information security risk management processes.

a) Organisation Information

Complete the organisation information before selecting a risk assessment approach.

- Organisation Name – Full legal name of the organisation
- Date – Assessment date (dd/mm/yyyy)
- Scope – Defined scope of the risk assessment

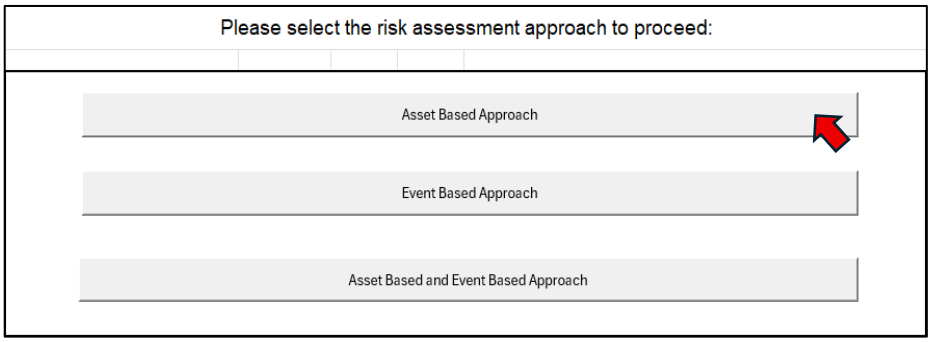


b) Risk Assessment Approach

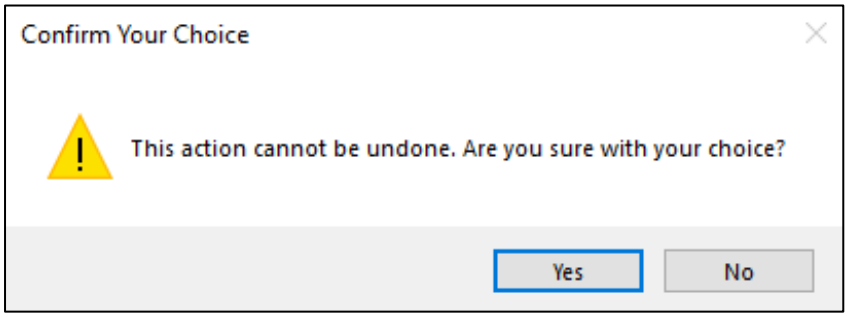
Select risk assessment approach for your organisation.

i) Asset Based Approach

1. Click on <Asset Based Approach>.

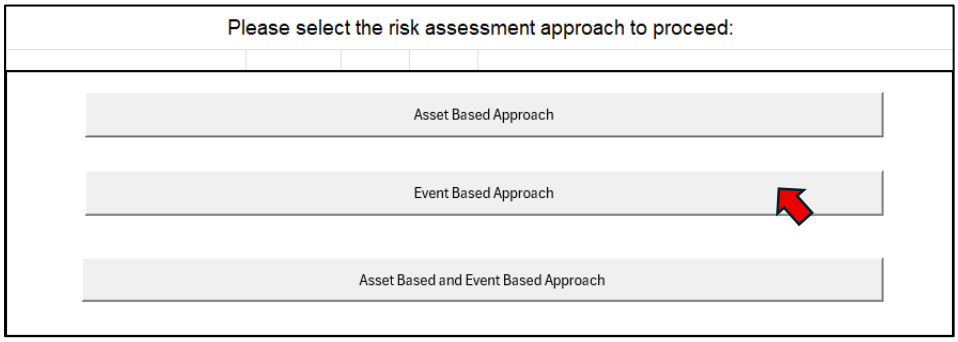


2. Once click on <Asset Based Approach>, a prompt will appear. Click <Yes> to continue.

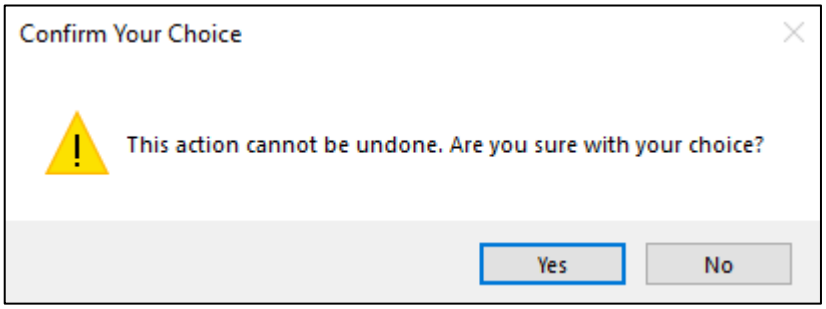


ii) Event Based Approach

1. Click on <Event Based Approach>.

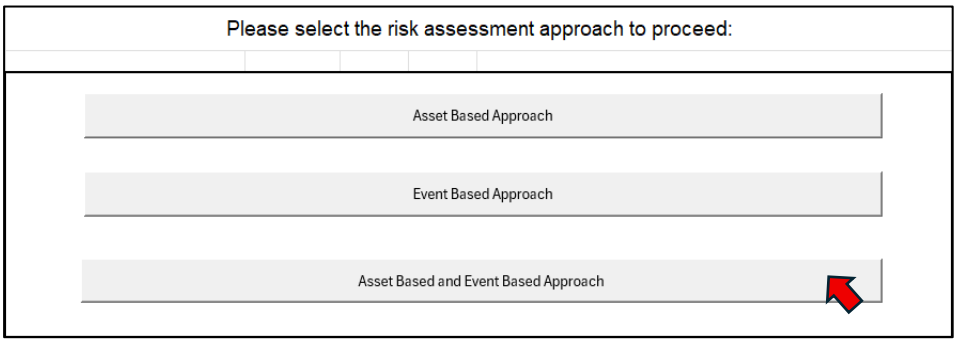


2. Once user click on <Event Based Approach>, a prompt will appear. Click <Yes> to continue.

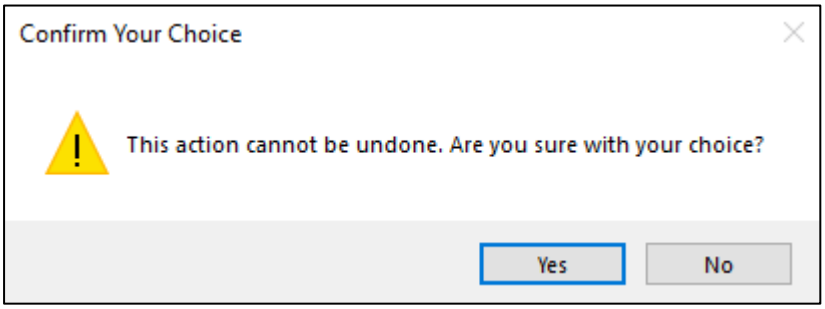


iii) Asset Based an Event Based Approach

1. Click on <Asset Based and Event Based Approach>



2. Once user click on <Asset Based and Event Based Approach>, a prompt will appear. Click <Yes> to continue.



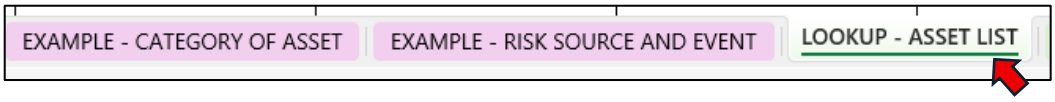
4.0 The Lookup Sheets

This section provides guidance on updating and managing the Lookup sheets to ensure accurate and consistent data within the ISRM Toolkit.

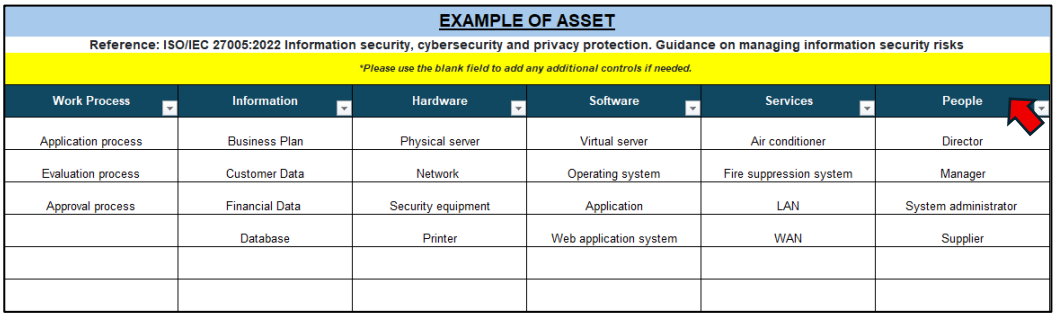
The Lookup sheets are provided to maintain supporting data for the asset information, threats, vulnerabilities, and controls data These lookup tables automatically update the dropdown list in the risk assessment forms, enabling easier and more consistent selection.

a) Lookup for Asset Information

1. Go to the <LOOKUP - ASSET LIST> sheet.



2. Insert a new column after the last existing asset category. Then, in the asset category row of the newly created column, enter the name of the new asset category.



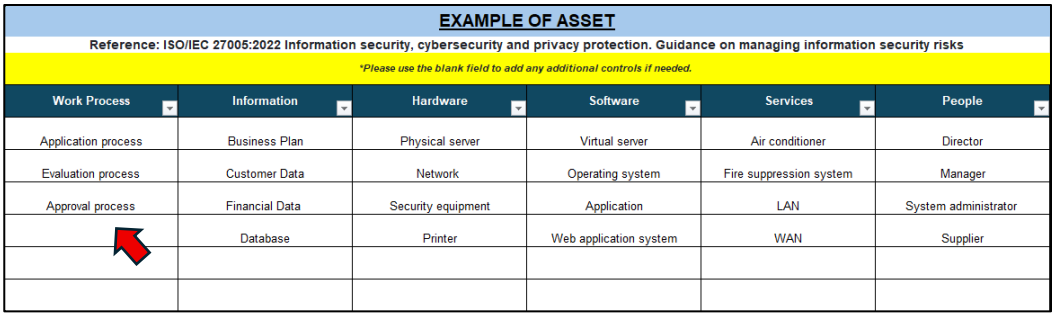
EXAMPLE OF ASSET

Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks

Please use the blank field to add any additional controls if needed.

Work Process	Information	Hardware	Software	Services	People
Application process	Business Plan	Physical server	Virtual server	Air conditioner	Director
Evaluation process	Customer Data	Network	Operating system	Fire suppression system	Manager
Approval process	Financial Data	Security equipment	Application	LAN	System administrator
	Database	Printer	Web application system	WAN	Supplier

3. In the relevant asset category, enter a new asset type in the corresponding field beneath that category.



EXAMPLE OF ASSET

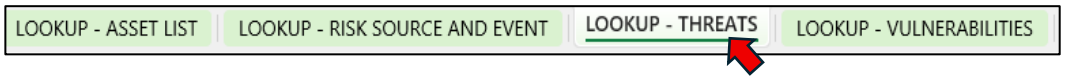
Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks

Please use the blank field to add any additional controls if needed.

Work Process	Information	Hardware	Software	Services	People
Application process	Business Plan	Physical server	Virtual server	Air conditioner	Director
Evaluation process	Customer Data	Network	Operating system	Fire suppression system	Manager
Approval process	Financial Data	Security equipment	Application	LAN	System administrator
	Database	Printer	Web application system	WAN	Supplier

b) Lookup for Threat Information

i) Go to the <LOOKUP - THREATS> sheet.



ii) Insert a new column after the last existing threat category. Then, in the threat category row of the newly created column, enter the name of the new threat category.

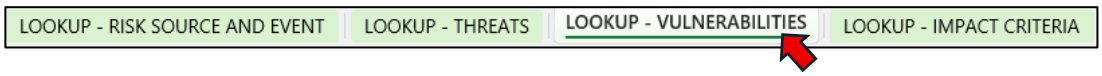
EXAMPLE OF THREATS						
Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks						
Please use the blank field to add any additional controls if needed.						
Physical threats	Natural threats	Infrastructure threats	Technical failures	Human Actions	Compromise functions or service	Organizational Threats
Dust, corrosion, freezing	Climatic phenomenon	Electromagnetic pulses	Failure of device or system	Corruption of data	Abuse of rights or permissions	Failure of service providers
Explosion	Flood	Electromagnetic radiation	Saturation of the information system	Damaging devices or media	Denial of actions	Lack of resources
Fire	Meteorological phenomenon	Failure of a supply system	Violation of information system maintainability	Data input from untrustworthy sources	Error in use	Lack of staff
Major accident	Pandemic/epidemic phenomenon	Failure of a telecommunications network		Disclosure of information	Forging of rights or permissions	Violation of laws or regulations
Pollution, harmful radiation	Seismic phenomenon	Failure of cooling or ventilation system		Drive-by-exploits using web-based communication		
Water	Volcanic phenomenon	Failure of telecommunication equipment		Eavesdropping		

iii) In the relevant threat category, enter a new threat type in the corresponding field beneath that category.

EXAMPLE OF THREATS						
Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks						
Please use the blank field to add any additional controls if needed.						
Physical threats	Natural threats	Infrastructure threats	Technical failures	Human Actions	Compromise functions or service	Organizational Threats
Dust, corrosion, freezing	Climatic phenomenon	Electromagnetic pulses	Failure of device or system	Corruption of data	Abuse of rights or permissions	Failure of service providers
Explosion	Flood	Electromagnetic radiation	Saturation of the information system	Damaging devices or media	Denial of actions	Lack of resources
Fire	Meteorological phenomenon	Failure of a supply system	Violation of information system maintainability	Data input from untrustworthy sources	Error in use	Lack of staff
Major accident	Pandemic/epidemic phenomenon	Failure of a telecommunications network		Disclosure of information	Forging of rights or permissions	Violation of laws or regulations
Pollution, harmful radiation	Seismic phenomenon	Failure of cooling or ventilation system		Drive-by-exploits using web-based communication		
Water	Volcanic phenomenon	Failure of telecommunication equipment		Eavesdropping		
		Loss of power supply		Fraudulent copying of software		
		Thermal radiation		Illegal processing of data		
				Incorrect use of devices		

c) Lookup for Vulnerability Information

i) Go to the <LOOKUP - VULNERABILITIES> sheet.



ii) Insert a new column after the last existing vulnerability category. Then, in the vulnerability category row of the newly created column, enter the name of the new vulnerability category.

EXAMPLE OF VULNERABILITIES

Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks

Please use the blank field to add any additional controls if needed.

Hardware	Software	Network	Personnel	Site	Organization
Insufficient maintenance/faulty installation of storage media	No or insufficient software testing	Insufficient mechanisms for the proof of sending or receiving a message	Absence of personnel	Inadequate or careless use of physical access control to buildings and rooms	Formal procedure for user registration and de-registration not developed, or its implementation is ineffective
Insufficient configuration change control	Applying application programs to the wrong data in terms of time	Inadequate network management (resilience of routing)	Inadequate recruitment procedures	Insufficient physical protection of the building, doors and windows	Audits (supervision) not conducted on a regular basis
Insufficient periodic replacement schemes for equipment	Complicated user interface	Inadequate network management (resilience of routing)	Incorrect use of software and hardware	Location in an area susceptible to flood	Change control procedure not developed, or its implementation is ineffective
Lack of care at disposal	Complicated user interface	Ineffective or lack of mechanisms for identification and authentication of sender and receiver	Ineffective or lack of policies for the correct use of telecommunications media and messaging	Unstable power grid	Continuity plans do not exist, or are incomplete, or are outdated
Lack of care at disposal	Disposal or reuse of storage media without proper erasure	Insecure network architecture	Insufficient or lack of monitoring mechanisms		Disciplinary process in case of information security incident not defined, or not functioning properly
Sensitivity to electromagnetic radiation	Failure to produce management reports	Poor joint cabling	Insufficient security training		E-mail usage policy not developed, or its implementation is ineffective
Susceptibility to humidity, dust, soiling	Immature or new software	Single point of failure	Poor security awareness		Formal policy on mobile computer usage not developed, or its implementation is ineffective
Susceptibility to temperature variations	Incorrect dates	Transfer of passwords in clear	Unsupervised work by outside or cleaning staff		Formal procedure for ISMS documentation control not developed, or its implemen- tation is ineffective
Susceptibility to voltage variations	Incorrect parameter set up	Unprotected communication lines			Formal procedure for ISMS record supervision not developed, or its implementation is ineffective
Uncontrolled copying	Ineffective change control	Unprotected public network connections			Formal process for access right review (supervision) not developed, or its implemen- tation is ineffective

iii) In the relevant threat category, enter a new threat type in the corresponding field beneath that category.

EXAMPLE OF VULNERABILITIES

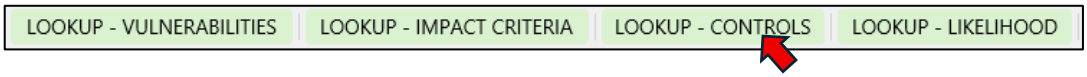
Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks

Please use the blank field to add any additional controls if needed.

Hardware	Software	Network	Personnel	Site	Organization
Insufficient maintenance/faulty installation of storage media	No or insufficient software testing	Insufficient mechanisms for the proof of sending or receiving a message	Absence of personnel	Inadequate or careless use of physical access control to buildings and rooms	Formal procedure for user registration and de-registration not developed, or its implementation is ineffective
Insufficient configuration change control	Applying application programs to the wrong data in terms of time	Inadequate network management (resilience of routing)	Inadequate recruitment procedures	Insufficient physical protection of the building, doors and windows	Audits (supervision) not conducted on a regular basis
Insufficient periodic replacement schemes for equipment	Complicated user interface	Inadequate network management (resilience of routing)	Incorrect use of software and hardware	Location in an area susceptible to flood	Change control procedure not developed, or its implementation is ineffective
Lack of care at disposal	Complicated user interface	Ineffective or lack of mechanisms for identification and authentication of sender and receiver	Ineffective or lack of policies for the correct use of telecommunications media and messaging	Unstable power grid	Continuity plans do not exist, or are incomplete, or are outdated
Lack of care at disposal	Disposal or reuse of storage media without proper erasure	Insecure network architecture	Insufficient or lack of monitoring mechanisms		Disciplinary process in case of information security incident not defined, or not functioning properly
Sensitivity to electromagnetic radiation	Failure to produce management reports	Poor joint cabling	Insufficient security training		E-mail usage policy not developed, or its implementation is ineffective
Susceptibility to humidity, dust, soiling	Immature or new software	Single point of failure	Poor security awareness		Formal policy on mobile computer usage not developed, or its implementation is ineffective
Susceptibility to temperature variations	Incorrect dates	Transfer of passwords in clear	Unsupervised work by outside or cleaning staff		Formal procedure for ISMS documentation control not developed, or its implemen- tation is ineffective
Susceptibility to voltage variations	Incorrect parameter set up	Unprotected communication lines			Formal procedure for ISMS record supervision not developed, or its implementation is ineffective
Uncontrolled copying	Ineffective change control	Unprotected public network connections			Formal process for access right review (supervision) not developed, or its implemen- tation is ineffective

d) Lookup for Controls Information

i) Go to the <LOOKUP - CONTROLS> sheet.



ii) Insert a new column after the last existing control category. Then, in the control category row of the newly created column, enter the name of the new control category.

EXAMPLE OF CONTROLS

Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks

Please use the blank field to add any additional controls if needed.

Organizational Controls	People Controls	Physical Controls	Technological Controls
Acceptable use of information and other associated assets	Confidentiality or non-disclosure agreements	Cabling security	Access to source code
Access control	Disciplinary process	Clear desk and clear screen	Application security requirements
Access rights	Information security event reporting	Equipment maintenance	Capacity management
addressing Information security within supplier agreements	Informations security awareness, education and training	Equipment siting and protection	Change management
Assessment and decision on information security events	Remote working	Physical entry	Clock synchronization
Authentication Information	Responsibilities after termination or change of employment	Physical security monitoring	Configuration management
Classification of information	Screening	Physical security perimeters	Data leakage prevention
Collection of evidence	Terms and conditions of employment	Protecting against physical and environmental threats	Data masking
Compliance with security policy and standards for information security		Secure disposal or re-use of equipment	Information access restriction
Contact with authorities		Securing offices, rooms and facilities	Information backup
Contact with special inerest groups		Security of assets off-premises	Information deletion
Documented Operating Procedures		Storage media	Installation of software on operational systems
ICT readiness for Business Continuity		Supporting utilities	Logging
Identity Management		Working in secure areas	Management of technical vulnerabilities

iii) In the relevant control category, enter a new control type in the corresponding field beneath that category.

EXAMPLE OF CONTROLS			
Reference: ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection. Guidance on managing information security risks			
*Please use the blank field to add any additional controls if needed.			
Organizational Controls	People Controls	Physical Controls	Technological Controls
Acceptable use of information and other associated assets	Confidentiality or non-disclosure agreements	Cabling security	Access to source code
Access control	Disciplinary process	Clear desk and clear screen	Application security requirements
Access rights	Information security event reporting	Equipment maintenance	Capacity management
addressing Information security wthin supplier agreements	Informations security awareness, education and training	Equipment siting and protection	Change management
Assessment and decision on information security events	Remote working	Physical entry	Clock synchronization
Authentication Information	Responsibilities after termination or change of employment	Physical security monitoring	Configuration management
Classification of information	Screening	Physical security perimeters	Data leakage prevention
Collection of evidence	Terms and conditions of employment	Protecting against physical and environmental threats	Data masking
Compliance with security policy and standards for information security		Secure disposal or re-use of equipment	Information access restriction
Contact with authorities		Securing offices, rooms and facilities	Information backup
Contact with special inerest groups		Security of assets off-premises	Information deletion
Documented Operating Procedures		Storage media	Installation of software on operational systems
ICT readiness for Business Continuity		Supporting utilities	Logging
Identity Management		Working in secure areas	Management of technical vulnerabilities

5.0 Team Profile

The <TEAM PROFILE> sheet allows users to create team profiles that can be utilized in both risk assessment and risk treatment. The steps provided are as follows:

a) Go to <TEAM PROFILE> sheet.

b) Complete the details of relevant team profile which include the following fields:

- ID – Must be a unique identifier for each personnel.
- Name – Enter the name of the personnel.
- Role – Specify their role in risk management.
- Department – Indicate which department the personnel belong to.

No.	ID	Name	Role *Role should not be limited to risk management team*	Department
3				
4				

6.0 Risk Assessment for Asset-based Approach

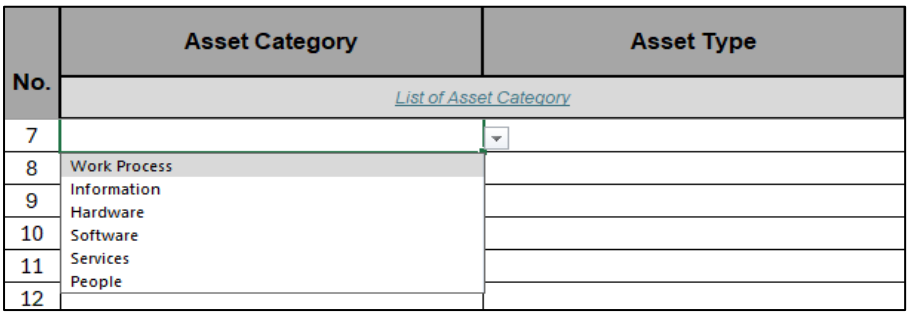
This section provides guidance on conducting risk assessment based specific assets. Users must enter key details such as the asset ID, threat, vulnerability, and existing control. Ensure that all required fields are completed accurately; otherwise, the risk will not be saved or reflected in other related sheets.

a) Creation of Asset Information

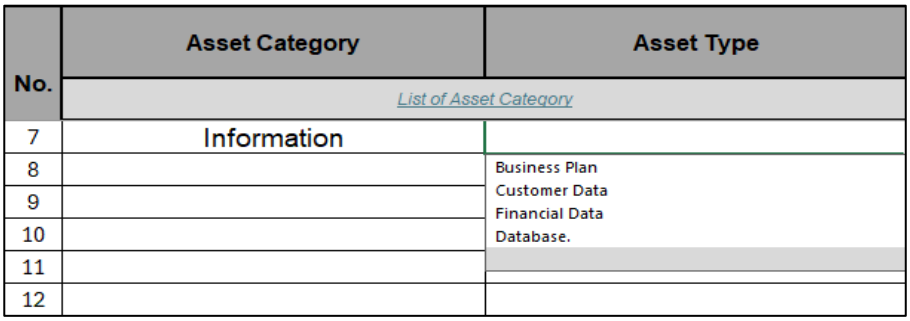
The following steps will guide users to create a new asset information:

i) Insert Asset Category and Asset Type

1. Go to <ASSET LIST> sheet.
2. To add an asset category, click the dropdown list and select the appropriate asset category from the list.



3. To add an asset type, click the dropdown list and select the appropriate asset type from the list.



4. Complete asset details in the remaining columns which contain of the following asset information:

   - Asset ID – Must be a unique identifier.

- Asset Name – Provide a clear name for the asset.
- Asset Location – Provide where the asset located.
- Asset Description – Description of the asset.

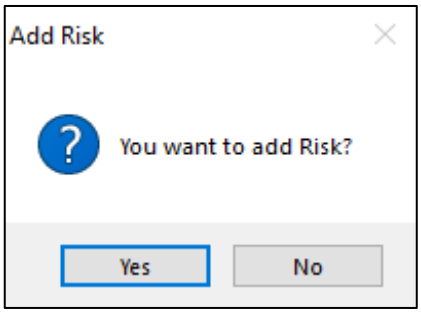
Asset ID *example: HW01, D101	Asset Name	Asset Location	Asset Description

b) Creation of Risk

The following steps will guide users to create a new risk information:

i) Add a new risk

1. Go to <RA – ASSET BASED> sheet.
2. Click on an empty cell under the <Risk ID> column to initiate a new risk record.
3. A prompt will appear asking if you want to add a new risk. Click <Yes> to proceed with creating a new Risk ID.



ii) Add asset information

1. Select <Asset ID> from the dropdown list.

ASSET ID	Asset Category	Asset Name
example: DI01, HW01		
HW001	Hardware	Router
HW001 IF001		

Note: This will auto-fill the corresponding <Asset Category> and <Asset Name> based on the entries in the <ASSET LIST> sheet.

iii) Add threat information

1. Select <Threat Category> from the dropdown list.

Threat Category	Threat Name
Please click on the link below for additional threats if needed List of Threats	
Physical threats Natural threats Infrastructure threats Technical failures Human Actions Compromise functions or services Organizational Threats	

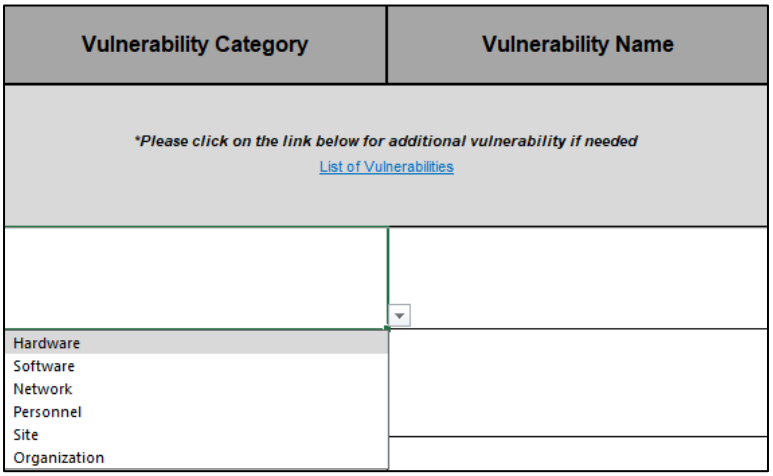
2. Select <Threat Name> that corresponds to the chosen threat category.

Threat Category	Threat Name
Please click on the link below for additional threats if needed List of Threats	
Technical failures	[Please Select]
	Failure of device or system Saturation of the information system Violation of information system maintainability

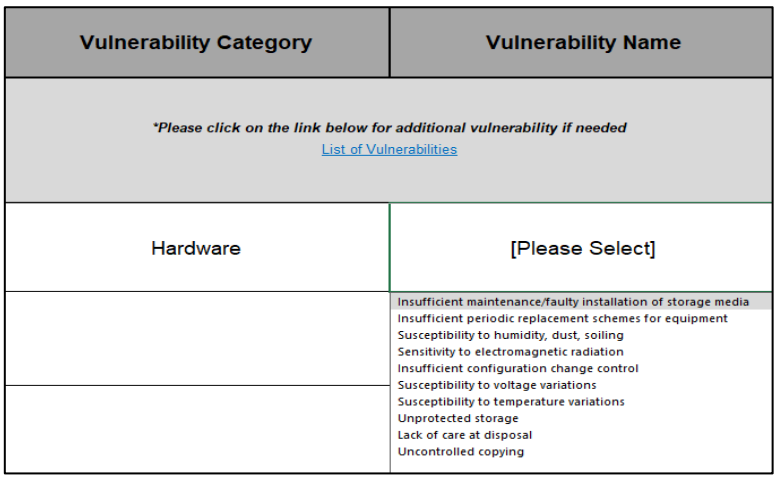
ASSET BASED | RA - EVENT BASED | RTP - EV

iv) Add vulnerability information

1. Select <Vulnerability Category> from the dropdown list.



2. Select <Vulnerability Name> that corresponds to the chosen vulnerability category.



v) Assign risk owner

1. Select a <Risk Owner> from the dropdown list.

Risk Owner *(Personnel)*
**Not limited to Information Security Risk Management Members* Team Profile
wani (analyst) afiq (engineer) nabilah (IT)

Note: The Risk Owner is not limited to Information Security Risk Management members. It can also include top stakeholders or individuals responsible for the risk.

c) Risk Analysis and Evaluation

i) Add Confidentiality (C), Integrity (I) and Availability (A) for impact information

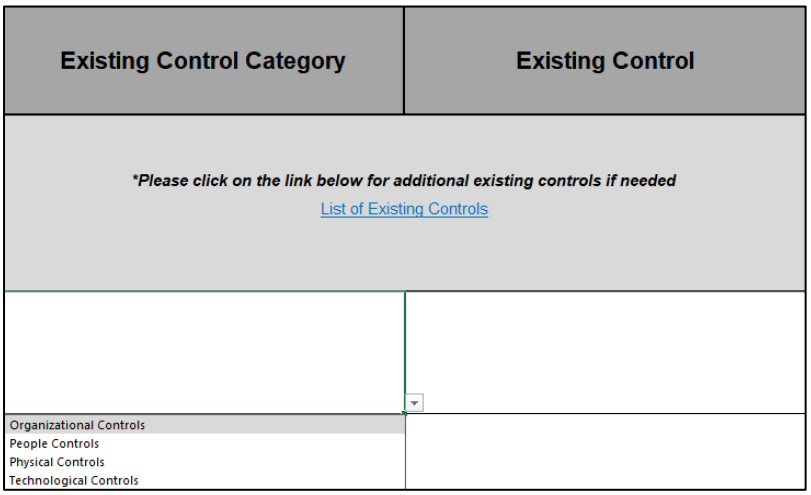
1. Select each C, I, A field to set the impact level. Available options are Very Low, Low, Medium, High or Very High.

Impact			**Impact Rating**
C *(Confidentiality)*	**I** *(Integrity)*	**A** *(Availability)*	
Reference of Impact Criteria			**Value is based on the highest of CIA*
Medium	High	Low	High
High Medium Low			

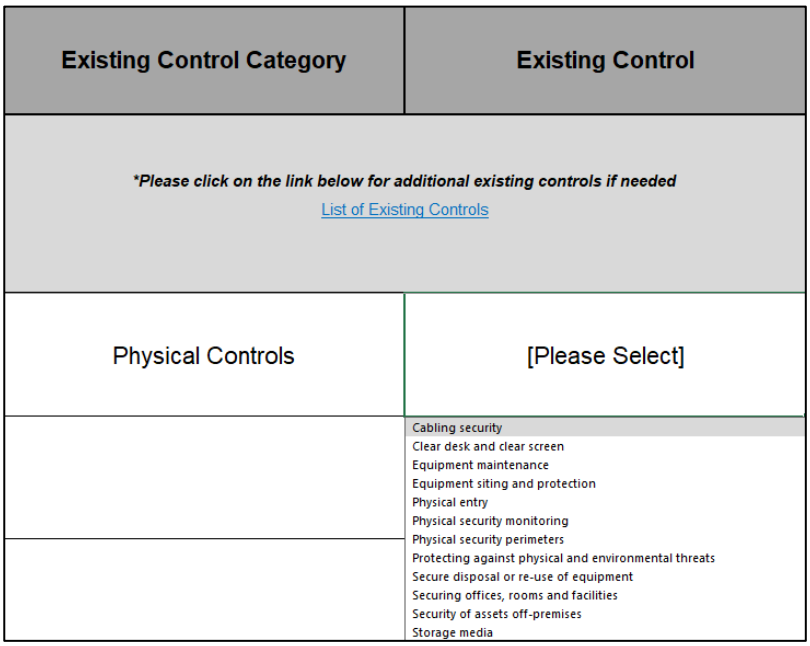
Note:
1. Kindly use the dropdowns provided for each field.
2. Impact Rating is determined based on the highest value among Confidentiality, Integrity, and Availability (CIA).

ii) Add existing control Information

1. Select <Existing Control Category> from the dropdown list.



2. Select <Existing Control> that corresponds to the chosen existing control category.



iii) Add likelihood level

1. Select <Likelihood> to set the likelihood level of risk event. Available options are Unlikely, Rather Unlikely, Likely, Very Likely or Almost Certain.

Likelihood	Level of Risk	Risk Evaluation
Reference of Likelihood	*Auto calculate (impact x likelihood)	Reference of Risk Evaluation
Almost Certain	Medium	Tolerable under controls
Unlikely Rather Unlikely Likely Very Likely Almost Certain		

Likelihood	Level of Risk	Risk Evaluation
Reference of Likelihood	*Auto calculate (impact x likelihood)	Reference of Risk Evaluation
Almost Certain	Medium	Tolerable under controls
Almost Certain	Very High	Unacceptable with immediate actions

Note: The <Level of Risk> and <Risk Evaluation> will be automatically generated based on the selected inputs.

iv) Add risk prioritisation

1. Select < Risk Prioritisation> from the dropdown list.

   - Yes: Approved for Risk Treatment Plan (RTP) escalation.
   - No: Not approved for escalation.

Risk Prioritisation
**Risk owner validation for risk treatment. (Yes = Approved for Risk Treatment Plan (RTP) escalation (Risk ID required) No = Not approved for escalation)*
Yes No

Note: Ensure the <Risk ID> column is filled before selecting risk prioritisation. Otherwise, it will not appear in the <RTP - ASSET BASED> sheet.

v) Justification to risk prioritization

1. Provide a brief explanation to support the decision in risk prioritization.

Justification
**Justification by risk owner for the risk prioritisation.*

d) Risk deletion

The steps to delete the risk:

i) Select <Risk ID> to be removed.

ii) Press ‘Delete’ on your keyboard.

Note: This action will also remove the associated entry in the <RTP – ASSET BASED> sheet automatically.

7.0 Risk Treatment Plan for Asset-based Approach

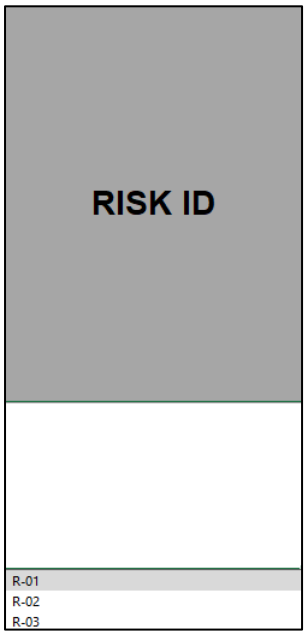
This section provides guidance on creating a risk treatment plan as a follow-up to the asset-based risk assessment activity. The plan serves as a structured approach to address risks that have been identified as requiring further treatment. It outlines the specific risk items, assigns responsible personnel, sets clear timelines, and defines the tracking process to monitor progress.

a) Creation of risk treatment plan

i) Add a new risk treatment

1. Go to <RTP – ASSET BASED> sheet.

2. Select <Risk ID> from dropdown list.

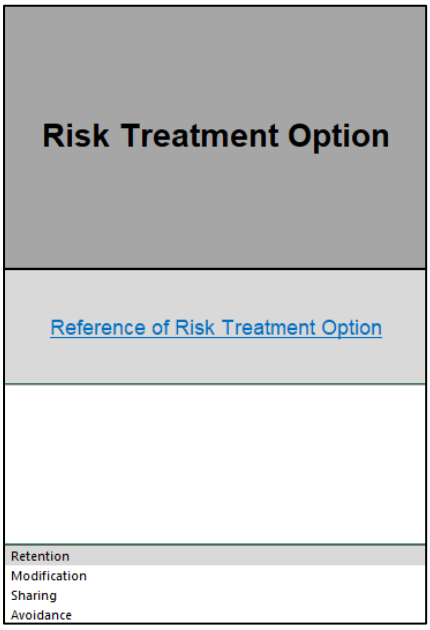


Result: The following fields will be auto-filled based on the selected Risk ID: - <Asset ID> - <Asset Name> - <Threat Category> - <Threat Name> - <Vulnerability Category> - <Vulnerability Name> - <Level of Risk> - <Risk Owner>.

Note: Only Risk ID with "Yes" in <Risk Prioritization> will appear in the <RTP – ASSET BASED> sheet

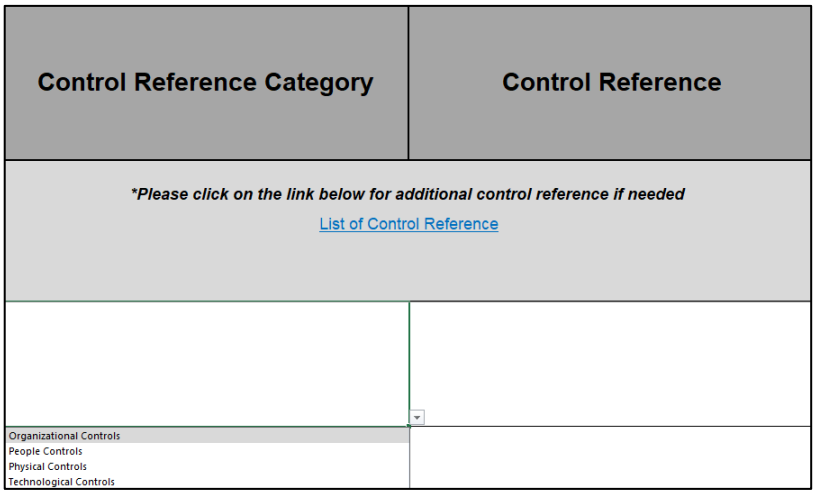
ii) Add risk treatment option

1. Select <Risk Treatment Option> from the dropdown list. Available options are Retention, Modification, Sharing, or Avoidance.



iii) Add Control Reference Information

1. Select <Control Reference Category> from the dropdown list.



2. Select a <Control Reference> that corresponds to the chosen control reference category.

Control Reference Category	Control Reference
*Please click on the link below for additional control reference if needed List of Control Reference	
People Controls	[Please Select]
	Confidentiality or non-disclosure agreements Disciplinary process Information security event reporting Informations security awareness, education and training Remote working Responsibilities after termination or change of employment Screening Terms and conditions of employment

b) Identification of Risk Treatment Activity

i) Add risk treatment activity

1. Go to the <Treatment Activity> column.
2. Manually insert the risk treatment activity in the designated field.

Treatment Activity
*Treatment activity for control reference

ii) Add responsible person for the risk treatment.

1. Go to the <Responsibility> column.

2. Select <Responsible> person from the dropdown list.

Responsibility
Team Profile ***Not limited to Information Security Risk Management Members***
wani (analyst) afiq (engineer) nabilah (IT)

**Note: The Responsible Person is not limited to Information Security Risk Management members. It can also include top stakeholders or individuals responsible for the risk treatment plan.*

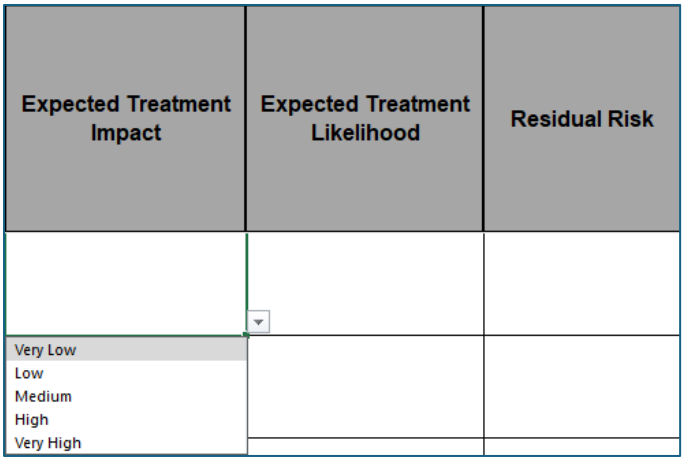
iii) Create the timeline

1. Go to <Timeline> column.
2. Enter Start Date and End Date in (dd/mm/yyyy) format.

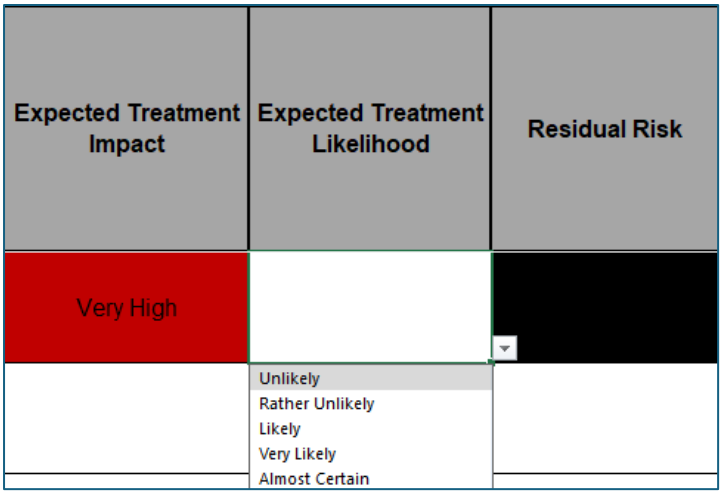
Timeline	
Start ***(dd/mm/yyyy)***	**End** ***(dd/mm/yyyy)***
19-Jun-2025	20-Apr-2027

iv) Add Residual Risk Information

1. Select <Expected Treatment Impact> from the dropdown list. Available options are Very Low, Low, Medium, High and Very High.



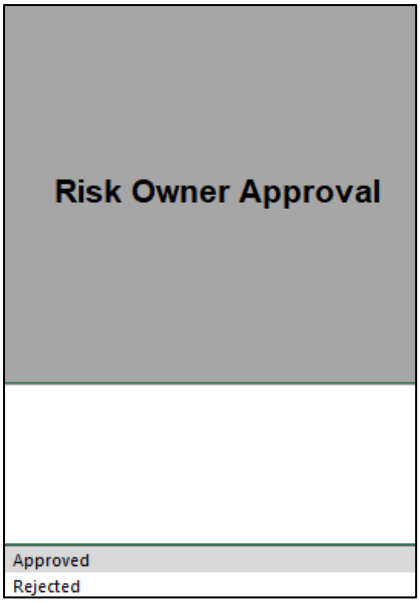
2. Select <Expected Treatment Likelihood> from the dropdown [Unlikely, Rather Unlikely, Likely, Very Likely or Almost Certain].



*Note: Residual Risk is auto calculated. Both fields must be selected to compute <Residual Risk>.

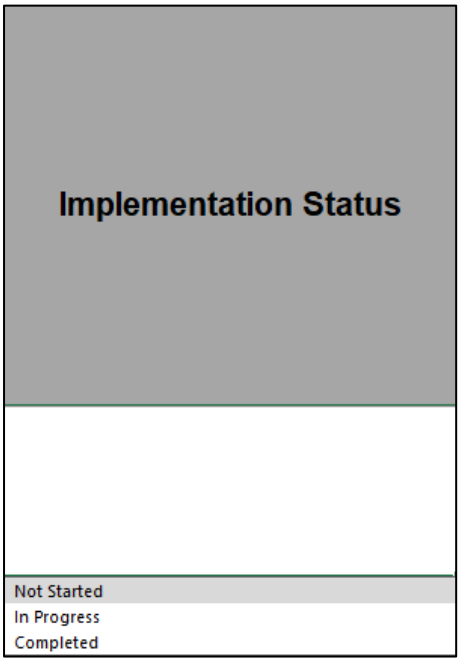
v) Risk owner approval

1. Go to <Risk Owner Approval> column.
2. Select either ‘Approved’ or ‘Rejected’ from the dropdown list.



vi) Status of risk treatment implementation

1. Go to <Implementation Status> column.
2. Select <Implementation Status> from the dropdown list. Available status are Not Started, In Progress or Completed.



8.0 Risk Assessment for Event-Based Approach

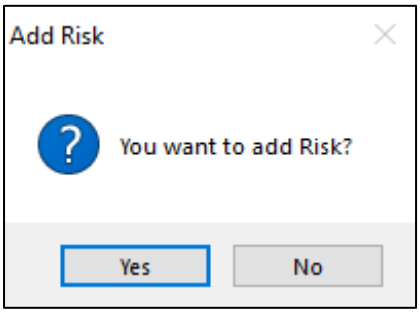
This section provides detailed guidance on conducting a risk assessment based on a specific event. The event-based approach focuses on incidents or situations that could impact multiple assets or systems simultaneously. This method is particularly useful for assessing risks arising from targeted attacks, operational disruptions, or scenario-based threats, enabling organizations to better anticipate and manage potential impacts.

a) Creation of Risk

The following steps will guide users to create a new risk information:

i) Add a new risk

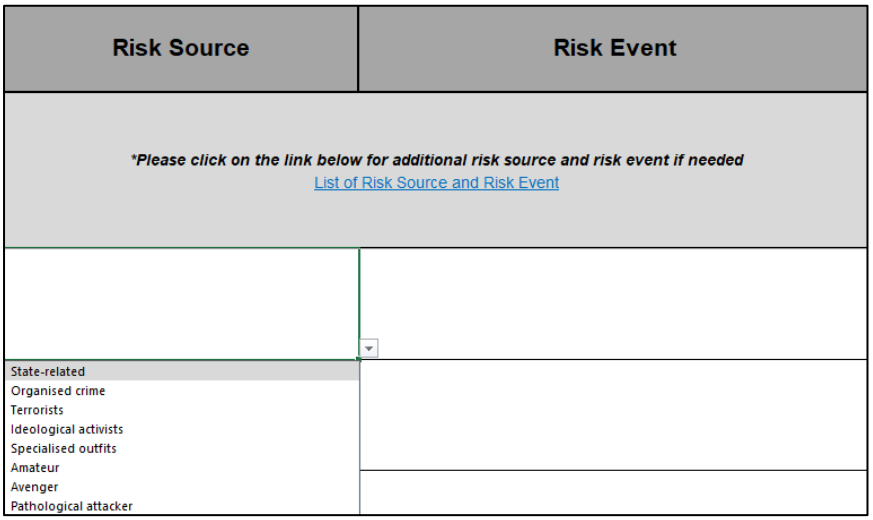
1. Go to <RA – EVENT BASED> sheet.
2. Click on an empty cell under the <Risk ID> column to initiate a new risk record.
3. A prompt will appear asking if you want to add a new risk. Click <Yes> to proceed with creating a new Risk ID.



b) Risk Identification

i) Add Risk Source and Risk Event

1. Select <Risk Source> from the dropdown list.



2. Select <Risk Event> that corresponds to the chosen risk source.

ii) Assign Risk Owner

1. Select <Risk Owner> from the dropdown list.

Risk Owner (Personnel)
*Not limited to Information Security Risk Management Members Team Profile
wani (analyst) afiq (engineer) nabilah (IT)

Note: The Risk Owner is not limited to Information Security Risk Management members. It can also include top stakeholders or individuals responsible for the risk

c) Risk Analysis and Evaluation

i) Add Confidentiality (C), Integrity (I) and Availability (A) for impact information

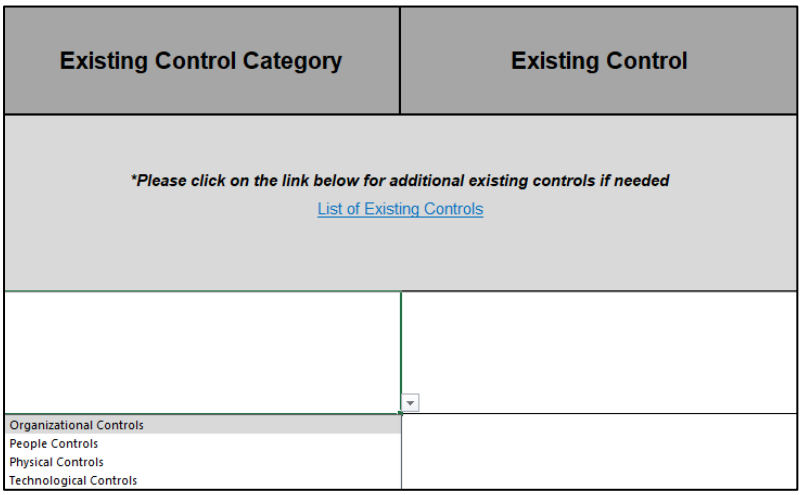
1. Select each C, I, A field to set the impact level. Available options are Very Low, Low, Medium, High or Very High.

Impact			Impact Rating
C (Confidentiality)	I (Integrity)	A (Availability)	
Reference of Impact Criteria			*Value is based on the highest of CIA
Very High	Very Low	Very Low	Very Low
Very Low Low Medium High Very High	Medium	Very High	Very High

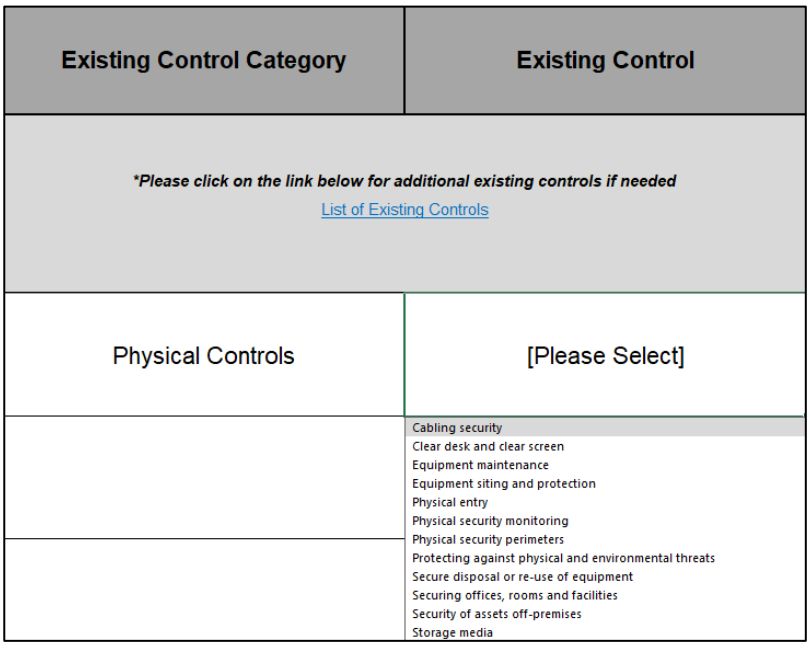
Note:
1. Kindly use the dropdowns provided for each field.
2. Impact Rating is determined based on the highest value among Confidentiality, Integrity, and Availability (CIA).

ii) Add existing control information

1. Select <Existing Control Category> from the dropdown list.



2. Select <Existing Control> that corresponds to the chosen existing control category.



iii) Add likelihood level

1. Select <Likelihood> to set the likelihood level of risk event. Available options are Unlikely, Rather Unlikely, Likely, Very Likely or Almost Certain.

Likelihood	Level of Risk	Risk Evaluation
Reference of Likelihood	***Auto calculate (impact x likelihood)***	*Reference of Risk Evaluation*
Almost Certain	Medium	Tolerable under controls
Unlikely Rather Unlikely Likely Very Likely Almost Certain		

Likelihood	Level of Risk	Risk Evaluation
Reference of Likelihood	***Auto calculate (impact x likelihood)***	*Reference of Risk Evaluation*
Almost Certain	Medium	Tolerable under controls
Almost Certain	Very High	Unacceptable with immediate actions

Note: The <Level of Risk> and <Risk Evaluation> will be automatically generated based on the selected inputs.

iv) Add risk prioritisation

1. Select < Risk Prioritisation> from the dropdown list.
   - Yes: Approved for Risk Treatment Plan (RTP) escalation.
   - No: Not approved for escalation.

Risk Prioritisation
**Risk owner validation for risk treatment. (Yes = Approved for Risk Treatment Plan (RTP) escalation (Risk ID required) No = Not approved for escalation)*
Yes No

**Note: Ensure the <Risk ID> column is filled before selecting Risk Prioritization. Otherwise, it will not appear in the <RTP - ASSET BASED> sheet.*

v) Justification to risk prioritization

1. Provide a brief explanation to support the selected risk prioritization decision.

Justification
**Justification by risk owner for the risk prioritisation.*

d) Risk Deletion

The steps to delete the risk:

i) Select <Risk ID> to be removed.

ii) Press ‘Delete’ on your keyboard.

Note: This action will also remove the associated entry in the <RTP – EVENT BASED > sheet automatically.

9.0 Risk Treatment Plan For Event-Based Approach

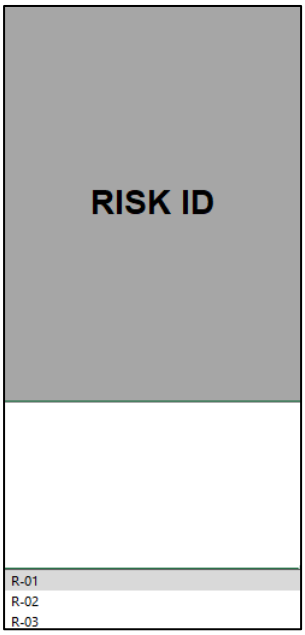
This section provides guidance on creating a risk treatment plan as a follow-up to the event-based risk assessment activity. The plan serves as a structured approach to address risks that have been identified as requiring further treatment. It outlines the specific risk items, assigns responsible personnel, sets clear timelines, and defines the tracking process to monitor progress.

a) Creation of risk treatment plan

i) Add a new risk treatment

1. Go to <RTP – **EVENT** BASED> sheet**.**

2. Select <Risk ID> from dropdown list.

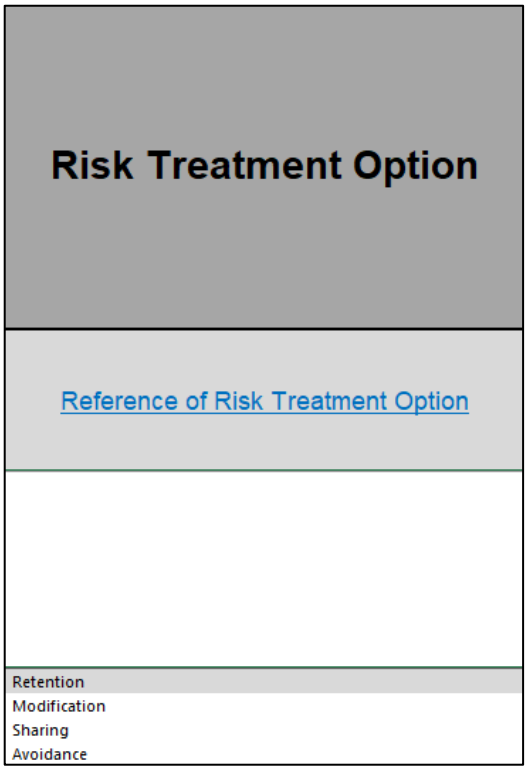


Result: The following fields will be auto-filled based on the selected Risk ID: - <Risk Event> - <Level of Risk> - <Risk Owner>.

Note: Only Risk ID with "Yes" in <Risk Prioritization> will appear in the <RTP – EVENT BASED> sheet.

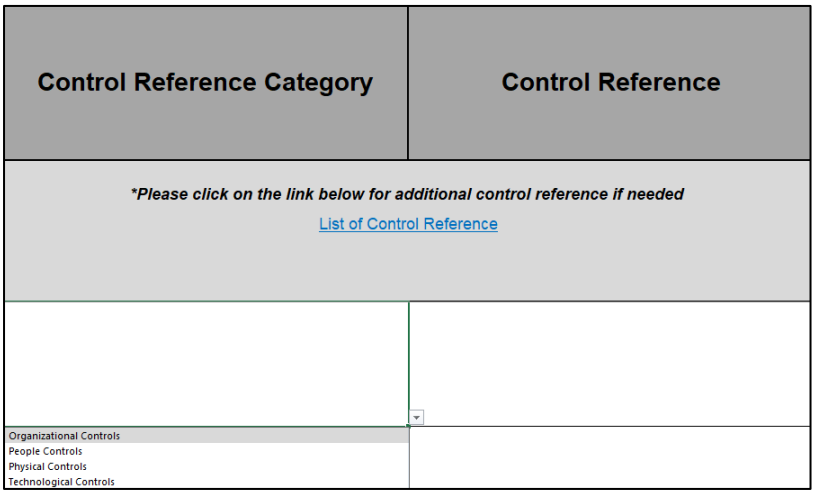
ii) Add risk treatment option

1. Select <Risk Treatment Option> from the dropdown list. Available options are Retention, Modification, Sharing, or Avoidance.



iii) Add Control Reference Information

1. Select <Control Reference Category> from the dropdown list.



2. Select <Control Reference> that corresponds to the chosen control reference category.

Control Reference Category	Control Reference
*Please click on the link below for additional control reference if needed List of Control Reference	
People Controls	[Please Select]
	Confidentiality or non-disclosure agreements Disciplinary process Information security event reporting Informations security awareness, education and training Remote working Responsibilities after termination or change of employment Screening Terms and conditions of employment

b) Identification of Risk Treatment Activity

i) Add risk treatment activity

1. Go to the <Treatment Activity> column.
2. Manually insert the risk treatment activity in the designated field.

Treatment Activity
Treatment activity for control reference

ii) Add responsible person for the risk treatment.

1. Go to the <Responsibility> column.
2. Select <Responsible> person from the dropdown list.

Responsibility
Team Profile ***Not limited to Information Security Risk Management Members***
wani (analyst) afiq (engineer) nabilah (IT)

Note: The Responsible Person is not limited to Information Security Risk Management members. It can also include top stakeholders or individuals responsible for the risk treatment plan.

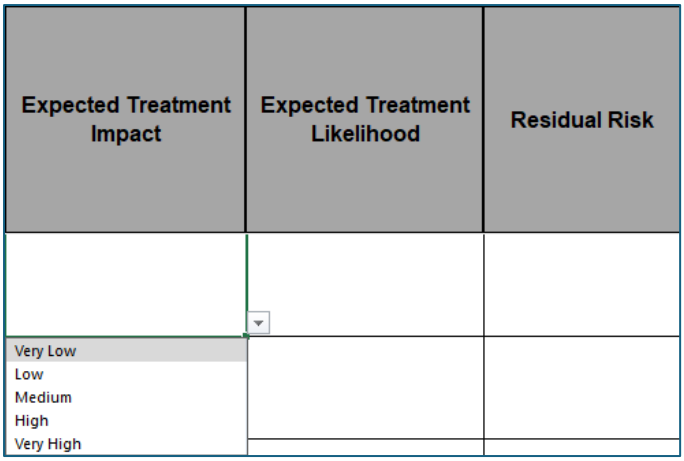
iii) Create the timeline

1. Go to <Timeline> column.
2. Enter Start Date and End Date in (dd/mm/yyyy) format.

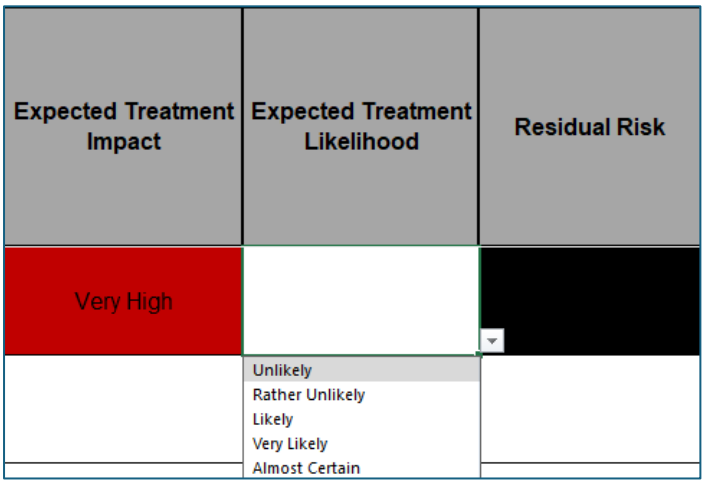
Timeline	
Start ***(dd/mm/yyyy)***	**End** ***(dd/mm/yyyy)***
19-Jun-2025	20-Apr-2027

iv) Add Residual Risk Information

1. Select <Expected Treatment Impact> from the dropdown list. Available options are Very Low, Low, Medium, High or Very High.



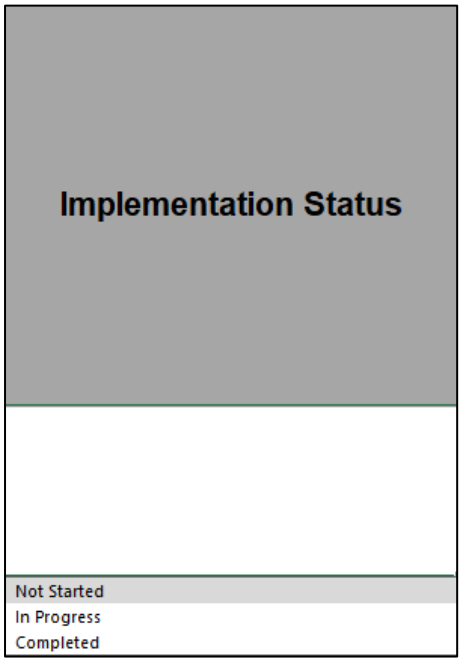
2. Select <Expected Treatment Likelihood> from the dropdown list. Available options are Unlikely, Rather Unlikely, Likely, Very Likely or Almost Certain.



**Note: Residual Risk is auto calculated. Both fields must be selected to compute <Residual Risk>.*

v) Risk owner approval

1. Go to <Risk Owner Approval> column.
2. Select either ‘Approved’ or ‘Rejected’ from the dropdown list.

vi) Status of risk treatment implementation

1. Go to <Implementation Status> column.
2. Select <Implementation Status> from the dropdown list. Available status are Not Started, In Progress or Completed.